SECURITY

Web Application Firewalls Visual Guide

A shield in front of your app —
filtering attacks before they reach your code.

ANIMATED WALKTHROUGH
Step through pages to play the animation

STEP 1/6

Where the WAF Sits

Every request passes inspection first.

Deploy at the edge (CDN), as a reverse proxy, or as a host module. Edge placement also absorbs junk before it costs you origin bandwidth.

STEP 2/6

Negative vs Positive Security Models

Block known-bad vs allow known-good.

Negative (blocklist)

Signatures for known attacks. Easy start, misses novel payloads.

Positive (allowlist)

Learn normal traffic; block the rest. Stronger, needs tuning.

Mature setups run both: blocklists for cheap wins, positive model for the crown-jewel endpoints.

STEP 3/6

OWASP Core Rule Set (CRS)

The community rule pack most WAFs start from.

Protocol
malformed requests

Injection
SQLi, XSS, RCE probes

Anomaly
scoring + thresholds

CRS scores anomalies per request and blocks past a threshold (paranoia levels 1–4). Higher paranoia = more blocks AND more false positives.

STEP 4/6

Tuning: Killing False Positives

A WAF that blocks customers is a self-inflicted DDoS.

- Start in detection/log-only mode — observe what WOULD block for 1–2 weeks.
- Whitelist by rule ID for legitimate patterns (rich text editors trip XSS rules).
- Tune per endpoint: strict on /admin, lenient on the marketing blog.
- Re-tune after every app release — new features create new 'anomalies'.

STEP 5/6

Virtual Patching & Rate Limiting

Buy time when code can't ship today.

Virtual patch

WAF rule blocks the exploit pattern while the real fix is coded.

Rate limiting

Throttle brute force, scraping, credential stuffing per IP/session.

Virtual patches are band-aids with expiry dates — track them like tech debt and remove when the code fix ships.

STEP 6/6

WAF Is One Layer

It reduces exposure; it doesn't replace secure code.

- WAFs can't see encrypted payloads they don't terminate, or logic flaws.
- Bypass techniques evolve — re-test your rules with each pentest.
- Pair with: secure coding, SAST/DAST, auth hardening, and monitoring.
- Measure: block rate, false-positive rate, time-to-tune after releases.

STEP ✓/✓

Key Takeaways

WAF — Remember

- The WAF inspects traffic before it reaches your app — deploy at the edge when you can.
- Negative model blocks known-bad; positive model allows known-good. Use both.
- OWASP CRS is the standard starting rule set; tune paranoia levels carefully.
- Always start in log-only mode and whitelist legitimate patterns per endpoint.
- Virtual patching buys time for real fixes; rate limiting blunts brute force.
- A WAF complements secure code — it never replaces it.

Keep exploring

Pair this guide with the matching video walkthroughs and hands-on labs at interstitiumlabs.dev